HAICHAIN

HAICHAIN ИНСТИТУЦИОНАЛЬНЫЙ АУДИТ БЕЗОПАСНОСТИ И ОЦЕНКА РИСКОВ

ОТЧЕТ О РИСКАХ ИНСТИТУЦИОНАЛЬНОГО УРОВНЯ V1.1 • СТАНДАРТ КРИПТОГРАФИЧЕСКОЙ ЗАЩИТЫ

HAICHAIN: Отчет об Институциональном Дью-Дилидженсе Рисков

Математические Доказательства, Моделирование Угроз и Матрица Верификации Red-Team для Инвесторов Tier-1

ЦЕЛЕВАЯ АУДИТОРИЯ
Фонды Tier-1 и Аудиторские Компании

КРИПТОГРАФИЧЕСКАЯ ЗАЩИТА
Аппаратный Passkey • 9 Инвариантов

ЯДРО ПРОТОКОЛА
HAICHAIN v1.1 • CapLeaf 223 Байта

ОТЧЕТ ОБ ИНСТИТУЦИОНАЛЬНОМ ДЬЮ-ДИЛИДЖЕНСЕ РИСКОВ HAICHAIN

Математические Доказательства, Моделирование Угроз и Матрица Верификации Red-Team

Целевая аудитория: Венчурные фонды Tier-1 (a16z crypto, Paradigm, Sequoia), институциональные кастодианы и ведущие аудиторские компании (OtterSec, Neodyme, Kudelski Security)
Версия протокола: HAICHAIN Kernel v1.1 / CapLeaf v1 (Сетевая схема 223 байта)
Технические стандарты: Anchor Framework (Solana L1) + Sui Move (`AgentCap`) + Tron Rail Intent Solver

1. ИСПОЛНИТЕЛЬНОЕ РЕЗЮМЕ И ПАРАДИГМА БЕЗОПАСНОСТИ

Автономные ИИ-агенты, осуществляющие микроплатежи, создают принципиально иные векторы атак по сравнению с традиционными DeFi: 1. **Нулевая задержка без участия человека:** ИИ-агент при выполнении вызовов инструментов может быть скомпрометирован посредством непрямой инъекции промпта (Indirect Prompt Injection) и выпустить тысячи несанкционированных платежных ваучеров за считанные секунды. 2. **Уязвимость утечки закрытых ключей:** Работа экземпляров агентов на распределенных узлах (Cloudflare Workers, локальные MCP, бессерверные функции) увеличивает риск компрометации закрытых ключей. 3. **Размножение мошеннических мерчантов (Sybil):** В открытой сети M2M злоумышленники могут регистрировать неограниченное количество временных доменов для обхода ограничений частоты запросов.

Для полного решения этой задачи без ущерба для субмиллисекундной скорости **HAICHAIN полностью разделяет исполнение платежей и хранение капитала**: - **Высший суверенный контроль:** Аппаратный биометрический ключ WebAuthn FIDO2 Passkey (P-256) сохраняет 100% суверенное владение пулом средств. - **Изоляция прав субагентов:** Временные пары ключей Ed25519 строго изолированы в межпроцессном механизме политик (Policy Engine) без доступа к мнемонической фразе кошелька. - **Ончейн Merkle-якорь:** Схема дескриптора полномочий (223 байта) жестко обеспечивает выполнение 9 математических инвариантов (I_1 ... I_9).

2. ФОРМАЛЬНАЯ МОДЕЛЬ УГРОЗ И ОГРАНИЧЕНИЕ УБЫТКОВ

2.1. Классификация поверхности атак

Класс угрозы	Сценарий	Традиционный риск Web3	Предельные потери в HAICHAIN
T_1 **(Инъекция промпта)**	LLM принуждают заплатить неавторизованному мерчанту	Полное опустошение кошелька $(100{,}000+)$	**E_{\text{theft}} = 0$** (Блокируется белым списком корня Merkle)
T_2 **(Сговор мерчанта)**	Легитимный мерчант пытается дважды заявить ваучер	Двойное списание с баланса	$E_{\text{theft}} = 0$ (Anchor гарантирует $P_i \le \min(C_i, R_i)$)
T_3 **(Атака через новый API)**	Субагент пытается истощить лимит на непроверенном API	Постепенное истощение пула	$E_{\text{theft}} \le M_{\text{tpl}}$ (Ограничено общим бюджетом шаблона)
T_4 **(Полный захват агента)**	Утечка ключа + сговор с мерчантом из белого списка	Мгновенный вывод всех средств	$E_{\text{theft}}(\tau) \le \min(B, K, W_p \cdot n(\tau, \omega_p))$

2.2. Теорема 6.1: Верхняя граница потерь в худшем сценарии (T_4)

Пусть τ – общее время отклика протокола от момента первой неавторизованной транзакции до подтверждения транзакции экстренной заморозки (Panic Freeze) в блокчейне:

$$\tau = t_{\text{detect}} + t_{\text{owner}} + t_{\text{land}}$$

где $t_{\text{detect}} \le 5.0\text{c}$, $t_{\text{owner}} \le 2.0\text{c}$, $t_{\text{land}} \le 5.0\text{c}$.

Максимальный совокупный ущерб $E_{\text{theft}}(\tau)$ математически строго ограничен:

$$E_{\text{theft}}(\tau) \le \min(B, \quad K, \quad W_p \cdot n(\tau, \omega_p), \quad \sum_{i:\, m_i \in <i>Ai>} E_i(\tau))$$

Вывод: Для институционального пула с балансом $10{,}000$ USDT, лимитом на лист 50 USDT и ограничением скорости 10 USDT / час, злоумышленник, получивший ключ агента, **не сможет похитить более** 10 **USDT** до срабатывания заморозки, сохраняя $9{,}990$ **USDT (99.9%)** средств фонда.

3. МАТРИЦА АППАРАТНОГО УКРЕПЛЕНИЯ RED-TEAM

	Вектор Атаки	Механизм Уязвимости	Аппаратный Ончейн Инвариант
1	**Двойное Списание Эскроу**	Отправка нескольких накопительных ваучеров на сумму выше лимита	**Монотонный Необратимый Расчет** $P_i \le \min(C_i, R_i)$: Аппаратная блокировка перерасхода
2	**Перехват Аккаунта ATA**	Подмена адреса получателя токенов на посторонний адрес	**Жесткая Каноническая Привязка** Валидация ассоциированного ATA на Solana L1
3	**Обход Panic Freeze**	Попытка закрыть канал после активации экстренной заморозки	**Мгновенная Изоляция Эпохи (I_6)** Все старые ваучеры аннулируются за 380 мс
4	**Вампирский Слив Аренды**	Хищение Lamports аренды при закрытии канала	**Возврат Аренды Создателю** Автоматический возврат 100% средств в `grant_pot`
5	**Sybil-Атака Микро-Циклов**	Создание 1 000 дочерних листьев для распыления баланса	**Сжигание Лимита Шаблона** `activate_child` списывает лимит из родительского пула

4. ОТЧЕТ ОБ АУДИТЕ 9 МАТЕМАТИЧЕСКИХ ИНВАРИАНТОВ ($I_1 \dots I_9$)

Все ончейн-инструкции в `programs/haichain-core/src/lib.rs` строго соблюдают 9 математических инвариантов состояния без исключений:

1. I_1 **(Сохранение Капитала):**

$$\text{Vault}_{\text{ATA}} + \sum_{\text{channels}} \text{Escrow}_j + \sum \text{Paid}_j + \text{Refunds} = \text{Чистые Депозиты}$$

Верифицировано тестом `test_invariant_i1_conservation` в тестовом наборе.

2. I_2 **(Безопасность Канонического Получателя):**

$$\texttt{payee_ata} \equiv \texttt{get_associated_token_address}(\text{merchant}, \text{mint})$$

Принудительно исполняется ончейн через Anchor; исключает подмену адреса третьими лицами.

3. I_3 **(Неприкосновенный Бюджетный Лимит):**

$$\text{consumed} \le \texttt{max_spend} \quad \wedge \quad \texttt{budget_used} \le \texttt{budget_total}$$

Проверяется перед каждой операцией резервирования или расчета.

4. I_4 **(Автономный Ограничитель Скорости):**

$$\texttt{window_used} \le \texttt{window_cap} \quad \forall t \in [T_0, T_0 + \omega]$$

Предотвращает быстрое автоматизированное исчерпание капитала.

5. I_5 **(Монотонное Сужение Полномочий PDA):**

$$\text{Channel PDA} \subseteq \text{Grant PDA} \subseteq \text{Pot PDA}$$

Дочерние инстансы не могут расширять права, предоставленные родителем.

6. I_6 **(Паническая Эпоха и Мгновенная Заморозка):**

$$\texttt{pot.panic_epoch} == \texttt{channel.created_at_epoch} \quad \wedge \quad \neg \texttt{pot.frozen}$$

Экстренная заморозка мгновенно аннулирует все незавершенные ваучеры.

7. I_7 **(Истечение Сессионного Тайм-аута):**

$$\texttt{current_time} \le \texttt{valid_until}$$

Истекшие или брошенные сессии не могут инициировать новые резервы.

8. I_8 **(Монотонный Однократный Расчет):**

$$\text{paid}_{\text{new}} \le \min(\texttt{cumulative_amount}, \texttt{reserved_amount}) \quad \wedge \quad \text{paid}_{\text{new}} \ge \text{paid}_{\text{old}}$$

Гарантирует абсолютное отсутствие двойного расходования средств.

9. I_9 **(Изоляция Счетов от Атак Сивиллы):**

$$\texttt{PDA}(\text{"chan"}, \text{grant}, \texttt{channel_id}) \text{ уникален}$$

Один лист полномочий сопоставляется ровно с одним ончейн-аккаунтом.

---

5. ТОКЕНОМИКА И РЕГУЛЯТОРНОЕ СООТВЕТСТВИЕ

- **100% Утилитарный стандарт (Иммунитет к Howey и MiCA):** Отсутствие пассивного стейкинга и дивидендов.
- **50% Buyback & Burn:** 50% сетевых сборов направляются на открытый выкуп $HAISI и постоянное сжигание.
- **50% Резервный фонд (CHGB):** Гарантия ликвидности и соблюдения SLA поставщиков.

---

6. ЗАКЛЮЧЕНИЕ И ДОСТУП К DATA ROOM

HAICHAIN v1.1 представляет собой первый в мире математически доказанный и аппаратно изолированный платежный уровень для автономных ИИ-агентов.